DOKUMEN REFERENSI KNOWLEDGE BASE - MODUL 04

KNOWLEDGE_DOCS: KEAMANAN APLIKASI WEB & MANAJEMEN KERENTANAN BISNIS

Panduan Proteksi Sistem Layanan Berbasis Web, Penilaian Risiko, dan Penutupan Celah Keamanan v1.0

RINGKASAN MODUL

Dokumen ini mengatur standar keamanan aplikasi web internal/eksternal perusahaan, pemindaian celah keamanan berulang, dan mekanisme audit risiko untuk menjaga keandalan sistem bisnis.

MODUL 1: Ancaman Utama Aplikasi Web (Kerangka OWASP Top 10)

Setiap aplikasi web perusahaan wajib dilindungi dari potensi celah keamanan kritis berikut:

Celah Keamanan	Deskripsi Singkat	Mitigasi Utama
SQL Injection (SQLi)	Penyisipan perintah SQL jahat ke formulir input untuk mengakses basis data internal.	Gunakan *Prepared Statements* dan validasi input yang ketat.
Cross-Site Scripting (XSS)	Penyuntikan skrip jahat ke halaman web yang dilihat oleh pengguna lain.	Terapkan pembatasan skrip dan enkoding output HTML.
Broken Authentication	Kelemahan pada manajemen sesi yang memungkinkan penyerang mencuri kredensial.	Gunakan pembatasan sesi, MFA, dan panjang kata sandi minimum.
Security Misconfiguration	Konfigurasi server atau layanan cloud yang terlalu terbuka atau menggunakan kredensial bawaan.	Ubah kata sandi default dan matikan port yang tidak digunakan.

MODUL 2: Siklus Manajemen Kerentanan (Vulnerability Management)

Bisnis wajib menjalankan 4 tahap berulang untuk mengidentifikasi dan menutup celah keamanan:

1. **Pemindaian Rutin (Scanning):** Melakukan pemindaian otomatis menggunakan pemindai celah keamanan terakreditasi minimal 1 bulan sekali.
2. **Prioritisasi Risiko (Prioritization):** Mengelompokkan celah berdasarkan tingkat keparahan (Kritis, Tinggi, Sedang, Rendah).
3. **Penambalan Sistem (Patching):** Mengaplikasikan pembaruan keamanan (*security patch*) pada perangkat lunak dan server utama.
4. **Pengujian Ulang (Verification):** Memastikan celah telah tertutup sepenuhnya dan tidak menimbulkan efek samping pada fungsi bisnis.

MODUL 3: Audit Keamanan Berkala & Uji Penetrasi (Penetration Testing)

- **Uji Penetrasi Tahunan:** Bisnis disarankan melakukan *Penetration Testing* oleh pihak independen minimal 1 tahun sekali.
- **Pencegahan Akses Langsung:** Pemasangan **Web Application Firewall (WAF)** di depan server aplikasi web untuk menyaring lalu lintas data mencurigakan secara otomatis.